

How Much Can Tool Trajectories Reveal?

A Leakage-Controlled Study of Cross-Session Attacks on LLM Agents

Xiangyi Li
Independent Researcher

ABSTRACT

Indirect prompt injection and multi-round attacks can distribute a harmful objective across otherwise ordinary tool calls. This paper measures how much information is available in tool-use trajectories under a leakage-controlled protocol. A reduced trajectory-only candidate is selected using development evidence (R1-R3), frozen before two independent API confirmation runs (R4-R5), and calibrated without test-set threshold selection. Across 480 attack groups and 400 benign test groups, it detects 139 attack attempts (29.0%), recalls 137 of 320 successful objectives (42.8%), and raises one benign alert (0.25%). Exact total-tool-call-count matching reduces detection to 22.2%-25.7%. Transition/frequency deviations provide the measured signal; removing the cross-session component changes detection by less than one percentage point. Removing cumulative scoring reaches 95%-100% in a post-confirmation exploratory ablation and therefore requires preregistered replication. The evidence is specific to one model family and a banking-style sandbox: tool trajectories provide useful but incomplete security evidence rather than a production-ready detector.

Index Terms - LLM agents, tool trajectories, cross-session attacks, behavioral anomaly detection, prompt injection, reproducible evaluation.

1. INTRODUCTION

LLM agents with tool-use capabilities are increasingly used for data retrieval, email, transactions, and workflow automation. Their risk surface is not limited to a single prompt: the same call can be benign in isolation and harmful when combined with earlier calls, persistent memory, or information imported from an untrusted document. This motivates monitoring the tool trajectory as a first-class security signal.

The evaluation problem is unusually sensitive to protocol choices. A detector may look strong when attack trajectories contain more calls than normal trajectories, when the threshold is selected on the test set, or when a defensive baseline changes the agent environment. We therefore focus on a narrow question: after development-time candidate selection is separated from confirmation, what detection-false-alarm trade-off does a tool-trajectory score provide?

The contribution is an auditable measurement study rather than a deployment claim. We freeze a trajectory-only candidate, evaluate it on two new API-executed runs, report group-level bootstrap intervals, match attack and benign trajectories by total tool-call count, and analyze failure modes. We also report an official AgentShield reference only as a separate-execution descriptive comparison.

The paper makes three deliberately bounded claims. First, TO-CF detects a measurable fraction of attack attempts at a low observed FPR in this sandbox. Second, transition/frequency deviations drive the measured signal, while the cross-session graph contributes little incremental benefit in these runs. Third, the detector misses many successful objectives, especially indirect injection, so the evidence does not support production readiness.

Research questions. RQ1 asks how much attack signal is present in tool trajectories after leakage and call-count confounding are controlled. RQ2 asks whether cross-session state improves over a session-only detector on attacks designed to require session linkage. RQ3 asks which attack families remain invisible to trajectory-only monitoring. RQ4 asks whether simple statistical baselines explain the observed performance.

2. RELATED WORK

AgentShield uses deception-based detection through honeytools and honeytokens at the tool interface. Its traps provide high-precision compromise signals, but they also alter the execution environment and therefore require careful comparison protocols. FragBench studies attacks whose malicious objective is fragmented across benign-looking interactions and motivates user-level or cross-session modeling.

The present work is complementary in scope. It does not claim to replace content-aware or deception-based defenses; it measures what can be recovered from tool-use trajectories alone. This distinction matters because a detector that sees only tool names and transition statistics cannot identify harmful intent that never changes the observable action pattern.

Several recurring evaluation risks motivate our protocol: test-set threshold tuning, leakage between normal splits, unreported attack-success denominators, and direct comparison of methods executed under different defenses. These are treated as design constraints rather than after-the-fact caveats.

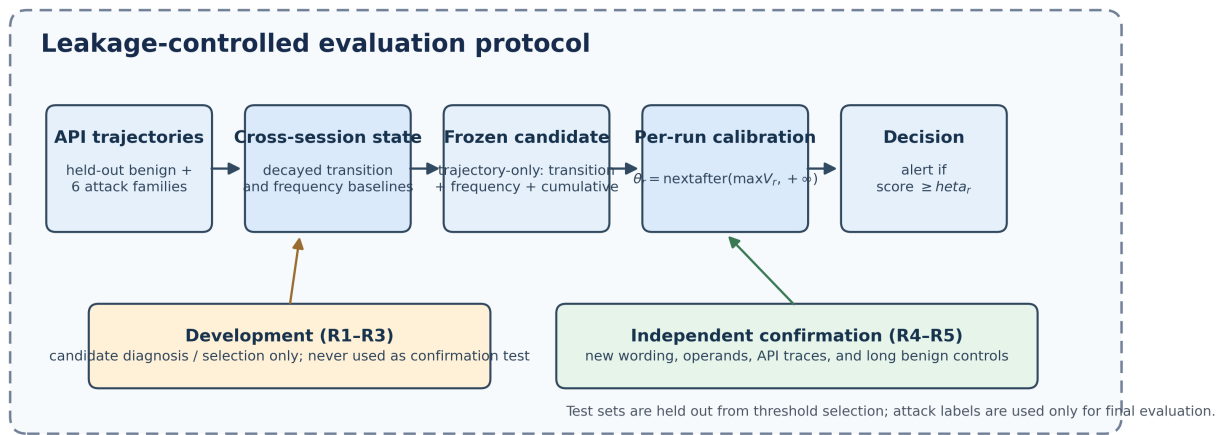


Fig. 1. Leakage-controlled evaluation protocol. Development R1-R3 is used for diagnosis and candidate selection only; TO-CF is frozen before independent confirmation R4-R5.

3. METHOD OVERVIEW

We distinguish two objects throughout the paper. Full-BG is the broad BehaviorGraph implementation containing graph-structure, parameter, tool-combination, transition/frequency, and cumulative components. TO-CF is the pre-registered trajectory-only confirmation candidate: parameter rules, tool-combination rules, and graph-structure scoring are disabled; transition/frequency deviations and cumulative scoring remain enabled. Only TO-CF is independently confirmed in R4/R5.

3.1 Graph representation

For a sequence of tool calls, the framework maintains a directed graph $G_t=(V_t, E_t, w_t)$. Nodes represent normalized tool invocations; edges represent consecutive calls. Within-session transitions and cross-session transitions share the state object, but the cross-session edge contribution is discounted during development to represent weaker temporal dependence. Repeated edges are reinforced and decayed over time. This representation is retained by the evaluator even when the graph-structure score is disabled for TO-CF.

3.2 Full-BG feature families

The full framework exposes seven graph diagnostics: density, tool diversity, normalized entropy, transition novelty, directed triangle count, PageRank centrality, and reciprocity. These features describe structural change, but the R4/R5 candidate does not use them in its primary score. The distinction is important: measuring a graph state and using graph structure as a scoring feature are not equivalent claims.

Development-only Full-BG scoring combines parameter anomaly, tool-combination anomaly, transition deviation, frequency deviation, and graph-structure anomaly. A representative legacy development configuration used weights 0.30, 0.30, 0.15, 0.10, and 0.15 respectively. Those weights are documented for provenance, not reported as independently confirmed performance.

3.3 Canonical TO-CF score

Let $q(c)$ denote the cumulative score after call c emitted by the locked transition/frequency candidate. For an ordered group g , the evaluator uses $S(g)=\max_c q(c)$, where state is retained across sessions in a multi-session group and the session boundary is reset without deleting the learned baseline. The alert indicator is $A(g)=1[S(g) \geq \theta]$. This is a score-and-threshold protocol; it is not the default `get_decision` path, whose instant rule and operational threshold are disabled during confirmation evaluation.

3.4 Calibration rule

For run r , V_r contains 100 benign validation groups: 50 short controls and 50 long controls. The canonical threshold is $\theta_r = \text{nextafter}(\max_{\{g \in V_r\}} S(g), +\infty)$. The `nextafter` operation ensures that a validation maximum is not itself alerted by the $\geq$ comparison. No test score, test label, or attack outcome is used to select θ_r .

TABLE I. Configuration boundary. Primary confirmation claims apply only to TO-CF.

Setting	Full-BG framework	TO-CF confirmation
Graph-structure score	enabled by default	disabled
Parameter rules	enabled by default	disabled
Tool-combination rules	enabled by default	disabled
Transition/frequency	available	enabled
Cumulative score	available	enabled
Independent confirmation	not run	R4 and R5

Each run contains 40 groups per family. Normal tasks are generated from multiple user profiles and include both short and long trajectories.

Development R1-R3 is used for feature diagnosis and candidate selection. R4-R5 use new wording and operands, independent API trajectories, and long benign controls. No confirmation trajectory is used to alter the candidate or threshold. A recorded failed long-control API attempt is retained as error metadata; recovered valid records are stored separately without overwriting earlier records.

4. EXPERIMENTAL PROTOCOL

The benchmark uses a banking-style synthetic tool environment with six attack families: delayed trigger, indirect prompt injection, persistent memory, privilege escalation, tool-chain exfiltration, and transaction cover.

4.1 Data splits and denominators

Per run, there are 200 calibration-normal groups, 100 validation-normal groups, 200 benign test groups, and 240 attack groups. Of the 240 attacks, 160 produce a successful underlying objective and 80 are attempted but incomplete. Successful-objective recall is therefore conditioned on 160 groups, while all-attempt detection uses all 240 attack groups. Raw records may contain multiple session records for one attack group; group-level denominators are the unit of analysis.

4.2 Statistical analysis

For each run we report the point estimate and a non-parametric 95% bootstrap interval over independent groups using 10,000 resamples. We report R4 and R5 separately because two repetitions are insufficient to establish broad stability. The macro mean and sample standard deviation are descriptive summaries, not a pooled claim of generalization.

4.3 Length control

To test whether a detector benefits simply from longer traces, attack and benign groups are matched exactly by total tool-call count without replacement. This is a secondary analysis: it reduces call-count confounding but does not match tool identity, semantic content, time intervals, or objective success.

TABLE II. Development/confirmation separation and per-run group counts.

Item	Development R1-R3	Confirmation R4-R5
Purpose	selection and diagnosis	frozen evaluation
Benign calibration	development-only	200 (100 short / 100 long)
Benign validation	not primary	100 (50 short / 50 long)
Benign test	not primary	200
Attack test	development templates	240 (40 per family)
Model execution	mixed historical runs	DeepSeek API, new wording/operands

5. CONFIRMATION RESULTS

TABLE III. Independent TO-CF confirmation results. Brackets are bootstrap 95% intervals; the macro column is descriptive, not a pooled population estimate.

Metric	R4	R5	Macro summary
Threshold	5.0040541339	4.9817326042	run-specific
All-attempt detection	68/240 = 28.3% [22.5,34.2]	71/240 = 29.6% [23.8,35.4]	descriptive
Successful recall	67/160 = 41.9% [34.4,49.4]	70/160 = 43.8% [36.3,51.9]	descriptive
Benign FPR	0/200 = 0.0% [0,0]	1/200 = 0.5% [0,1.5]	observed
Exact count matched	26/117 = 22.2% [14.5,29.9]	29/113 = 25.7% [17.7,33.6]	secondary

The two runs are numerically similar, but overlapping intervals do not establish broad stability. The aggregate is reported only as a descriptive macro summary. The low observed FPR is accompanied by limited recall: most successful objectives remain below the frozen threshold.

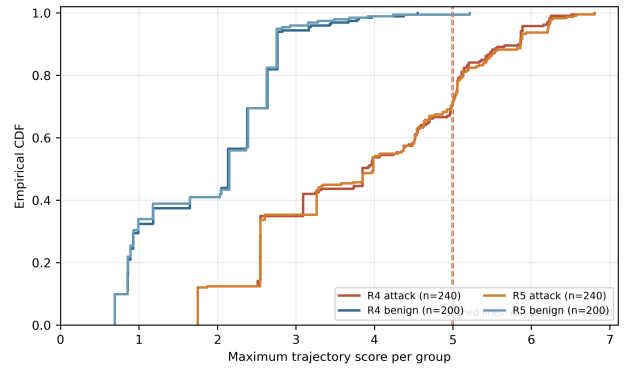


Fig. 2. Empirical distributions of maximum trajectory score for attack and benign groups. Dashed lines are the run-specific validation-maximum thresholds.

5.1 Attack-family heterogeneity

TABLE IV. All-attempt detection by attack family. Successful-objective recall has a separate denominator.

Attack family	R4 all-attempt	R5 all-attempt
Delayed trigger	0/40 = 0%	0/40 = 0%
Indirect injection	0/40 = 0%	0/40 = 0%
Persistent memory	1/40 = 2.5%	1/40 = 2.5%
Privilege escalation	35/40 = 87.5%	37/40 = 92.5%
Tool-chain exfiltration	16/40 = 40%	17/40 = 42.5%
Transaction cover	16/40 = 40%	16/40 = 40%

The family breakdown is highly heterogeneous. Privilege escalation generates unusual tool transitions in this sandbox, while delayed trigger and indirect injection often preserve ordinary-looking calls. These differences are not evidence that one family is intrinsically easier in general; they describe this task and tool distribution.

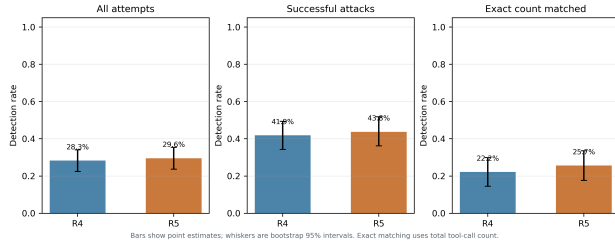


Fig. 3. Primary TO-CF metrics. Error bars are bootstrap 95% intervals; exact matching is by total tool-call count.

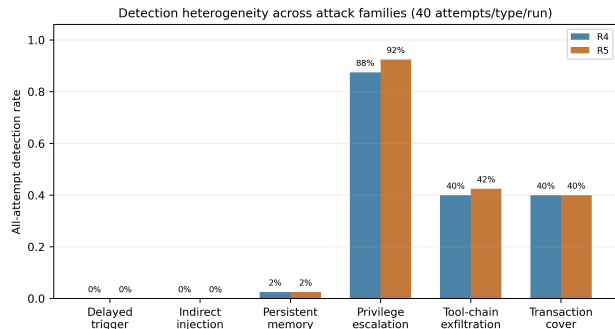


Fig. 4. All-attempt detection heterogeneity across six attack families. This is a family breakdown, not a missed-case-only chart.

5.2 Length-matched evaluation

The exact count-matched rates are lower than the unmatched all-attempt rates in both runs. This rules out the interpretation that the headline detection rate is purely a consequence of attacks having more calls, although residual confounding remains because matched groups can still differ in semantics and tool identity.

5.3 Same-trajectory baselines

Four trajectory-only comparators were fitted and calibrated on the identical R4/R5 groups: normalized tool-frequency z-scores, first-order Markov transition surprise, a regularized Mahalanobis detector over tool/transition proportions, and Isolation Forest. The results show why a new detector claim requires matched baselines: simple methods range from zero detection to high detection with very different recall profiles. None uses natural-language content or changes the agent environment.

TABLE V. Same-trajectory baseline results. Each cell reports all-attempt detection / successful-objective recall / benign FPR; Wilson intervals are in the JSON artifacts.

Method	R4: all / success / FPR	R5: all / success / FPR
Tool-frequency z	21.3% / 0.0% / 1.0%	21.3% / 0.0% / 1.0%
Markov transition	0.0% / 0.0% / 0.0%	0.0% / 0.0% / 0.0%
Mahalanobis	88.8% / 83.1% / 0.0%	94.2% / 91.3% / 0.0%
Isolation Forest	0.0% / 0.0% / 0.0%	0.0% / 0.0% / 0.0%

6. MECHANISM DIAGNOSTICS

The ablation analysis was run after observing confirmation results and is therefore exploratory. Each ablation is recalibrated using its own validation-maximum threshold. The no-cross-session variant changes all-attempt detection by 0.4 percentage points in both runs. Removing transition/frequency signals eliminates detection. Removing cumulative scoring produces 95.0% and 100.0%, but this finding is not a confirmatory method result.

TABLE VI. Post-confirmation ablation. No row except TO-CF is a locked primary result.

Configuration	R4	R5	Status
Frozen TO-CF	28.3%	29.6%	primary
No cross-session	27.9%	29.2%	exploratory
No transition/frequency	0.0%	0.0%	exploratory
No cumulative	95.0%	100.0%	post-hoc hypothesis

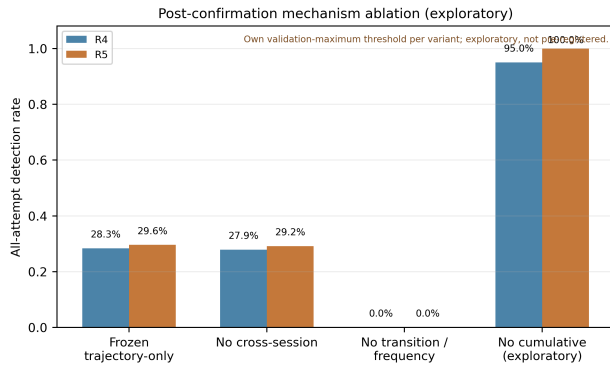


Fig. 5. Exploratory mechanism ablation. The no-cumulative result requires preregistered R6/R7 replication.

6.1 Failure analysis

Across R4/R5, TO-CF misses 183 successful objectives: 80 indirect-injection cases (44%), 47 tool-chain exfiltration cases (26%), 48 transaction-cover cases (26%), and 8 privilege-escalation cases (4%). The dominant failure mode is semantic indistinguishability: a malicious instruction can cause a normal-looking read-then-send sequence, leaving no unusual transition for a trajectory-only score to detect.

The R5 benign false positive is a normal session containing multiple `export_data` calls with null reasons. This is a useful diagnostic rather than evidence of an attack: rare but legitimate workflow variants can cross a threshold calibrated on a limited normal sample.

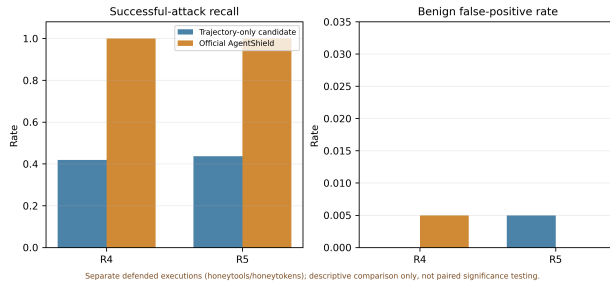


Fig. 6. Separate-execution AgentShield reference. Honeytool/honeytoken intervention changes the environment; no paired significance claim is made.

7. BASELINE CONTEXT

The official AgentShield adapter was run in separate defended executions because its honeytools and honeytokens modify the tool interface and the resulting agent trajectory. It obtains 67.1%/66.7% all-attempt detection, 100%/100% successful-objective recall, and 0.5%/0.0% FPR in R4/R5. These values are descriptive references. They do not come from paired replays of the same trajectory, so paired significance tests and causal superiority claims are invalid.

The comparison illustrates complementarity rather than a winner. Deception-based signals can directly expose an attacker's interaction with a trap, whereas TO-CF observes only the resulting sequence of ordinary tools. A practical system could combine both channels, but such a hybrid is outside the present confirmation scope.

8. THREATS TO VALIDITY

Model scope. All primary results use one API-accessible model family and function-calling setup. No cross-model transfer claim is made.

Environment scope. The banking-style sandbox and synthetic tasks are controlled and reproducible but do not represent natural production traffic, tool diversity, or organizational workflows.

Attack scope. Six families and fixed templates cannot cover adaptive attackers. In particular, an attacker who optimizes for ordinary-looking tool sequences may evade trajectory-only detection.

Statistical scope. There are 400 independent benign test groups and only two confirmation repetitions. The observed FPR is therefore uncertain and should not be treated as a universal operational false-alarm guarantee.

Method scope. Full-BG was not independently confirmed. The cross-session component is retained in evaluator state but contributes less than one percentage point in this benchmark. No-cumulative was selected post-hoc and requires a new preregistration.

Baseline scope. AgentShield's honeytool/honeytoken intervention prevents paired causal attribution. Its result is a separate execution reference only.

9. REPRODUCIBILITY PACKAGE

All raw confirmation records and derived artifacts are versioned under `local_results/canonical/`. The protocol and source hashes are recorded in `confirmation_preregistration_20260730.json` and `development_freeze_20260730.json`. The independent audit is `experiments/audit_submission_consistency.py`; its output is `output/audit/submission_consistency.json`. The corrected figure generator and this PDF builder are included so a collaborator can regenerate the complete paper without relying on the original PDF.

TABLE VII. Reproducibility artifacts included with the submission package.

Artifact	Purpose
<code>confirmation_preregistration_20260730.json</code>	Locked TO-CF candidate, sample sizes, threshold, endpoints
<code>confirmation_R4/</code> and <code>confirmation_R5/</code>	Raw records, indices, evaluations, long controls
<code>confirmation_paper_artifacts/</code>	Summary JSON, misses CSV, paper-ready plots
<code>audit_submission_consistency.py</code>	Independent threshold/denominator/ablation audit
<code>assets_corrected/manifest.json</code>	Six figure names, data source, comparison disclosures

10. FUTURE WORK

The next experiment should be preregistered before data collection. R6/R7 should test the no-cumulative hypothesis with new attack wordings, operands, normal trajectories, and fixed endpoints. If the full BehaviorGraph framework is to remain in the title or contribution claim, it also requires independent Full-BG confirmation. A stronger system should evaluate hybrid content-plus-trajectory signals, multiple model families, multiple tool domains, adaptive attackers, detection latency, and computational cost.

11. CONCLUSION

This paper presents a complete, leakage-controlled measurement of a trajectory-only candidate derived from a cross-session BehaviorGraph framework. Under the reported benchmark conditions, TO-CF detects 29.0% of attack attempts and recalls 42.8% of successful objectives at a 0.25% observed FPR. Exact call-count matching lowers detection, and failure analysis shows that ordinary-looking tool sequences remain a major blind spot. Transition/frequency deviations drive the signal; the measured incremental value of cross-session graph structure is small. The scientifically defensible conclusion is therefore bounded: tool trajectories provide useful but incomplete evidence, and a production detector requires content-aware or deception-based complementarity plus broader independent validation.

REFERENCES

- [1] Y. H. Rassul and T. A. Rashid, "AgentShield: Deception-based Compromise Detection for Tool-using LLM Agents," arXiv:2605.11026, 2026.
- [2] A. Mehta et al., "FragBench: Cross-Session Attacks Hidden in Benign-Looking Fragments," arXiv:2605.11029, 2026.
- [3] Open Worldwide Application Security Project, "OWASP Top 10 for LLM Applications," 2025 edition.
- [4] The canonical protocol, source hashes, raw records, and audit scripts are included in this repository's reproducibility package; see README.md and docs/FINAL_REVIEW_AND_REVISION_LOG.md.

APPENDIX A. AUDIT AND REBUILD CHECKLIST

The final PDF was rebuilt from the corrected six-figure asset set. The independent audit checks: R4/R5 thresholds; validation and benign alert counts; attack and successful-objective denominators; per-family alert counts; missed-success totals; and the exploratory ablation values. The audit reports passed=true for both confirmation runs.

TABLE VIII. Machine-checked audit invariants.

Check	R4	R5	Expected invariant
Validation groups	100	100	exactly 100
Benign test groups	200	200	exactly 200
Attack groups	240	240	exactly 240
Threshold > validation max	pass	pass	strictly greater
Test labels used in calibration	no	no	never
No-transition ablation	0.0%	0.0%	exploratory only

A collaborator can rebuild the figures and PDF with `pip install -r requirements.txt`, then run `python experiments/generate_corrected_figures.py`, `python experiments/audit_submission_consistency.py`, and `python experiments/build_complete_submission_pdf.py`. API collection is not needed to reproduce the checked-in paper outputs.